INFORME DE SEGURIDAD – REPORTE DE HALLAZGOS Y VULNERABILIDADES

Evaluación de Seguridad Ofensiva, Hackeo Ético y Verificación OWASP ASVS v4.0.3

NOVIEMBRE DE 2026

CONFIDENCIAL – REPORTE DE SEGURIDAD E INFORMACIÓN DE AUDITORÍA

1. Resumen Ejecutivo y Ficha Técnica

El presente informe consolida los resultados de la evaluación de seguridad realizada sobre la aplicación web **Turnero**, en el m arco de una práctica de auditoría de seguridad en un entorno controlado, con el objetivo de identificar vulnerabilidades que puedan comprometer la confidencialidad, integridad o disponibilidad de la información.

Durante las pruebas se identificó una vulnerabilidad de control de acceso de tipo **IDOR/BOLA (Insecure Direct Object Refer ence / Broken Object Level Authorization)**, que permite a un usuario autenticado consultar y eliminar turnos pertenecientes a otros usuarios mediante la manipulación de identificadores en las solicitudes HTTP.

Se documenta el hallazgo identificado, su nivel de severidad, los recursos afectados, el procedimiento utilizado para demost rar su existencia, las evidencias obtenidas y las recomendaciones necesarias para su corrección.

El reporte permite comprender el riesgo asociado a la vulnerabilidad detectada y facilita la priorización de las acciones corre ctivas correspondientes.

Ficha técnica de la evaluación

Parámetro	Detalle
Sistema evaluado	Turnero
Tipo de evaluación	Auditoría de seguridad de caja negra
Fecha de evaluación	11/11/2026
Entorno evaluado	Entorno controlado
Alcance	Aplicación web Turnero y endpoints de su API relacionados con l a consulta y eliminación de turnos.
Metodología	Pruebas manuales de seguridad, análisis de solicitudes HTTP y v erificación de controles de autorización mediante manipulación de identificadores.
Estándar de referencia	OWASP Top 10 2021 – A01: Broken Access Control / OWASP API Security Top 10 2023 – API1: Broken Object Level Authorization.
Clasificación del documento	CONFIDENCIAL

2. Alcance y Metodología de Evaluación

La evaluación se realizó sobre la aplicación web Turnero, en un entorno de laboratorio controlado, con el objetivo de analizar l os mecanismos de control de acceso relacionados con la consulta y eliminación de turnos.

El alcance de las pruebas comprendió:

- **Autenticación y gestión de sesiones:** utilización de una cuenta autenticada para realizar las solicitudes HTTP y verificar los permisos asociados a dicha sesión.
- **Control de acceso:** evaluación de los mecanismos de autorización sobre los turnos pertenecientes a distintos usuarios, mediante la manipulación de identificadores en las solicitudes.
- **Seguridad de la API:** análisis de los endpoints utilizados para consultar los turnos de un usuario y eliminar turnos individual es.
- **Validación de permisos a nivel de objeto:** comprobación de que las operaciones solicitadas estuvieran restringidas a los recursos sobre los cuales el usuario autenticado tenía autorización.

La metodología utilizada consistió en pruebas manuales de caja negra, mediante la inspección, modificación y envío de solici tudes HTTP, y el análisis de las respuestas proporcionadas por el servidor.

Las pruebas se enfocaron en los siguientes endpoints:

```
GET /api/{user_id}/appointments/
DELETE /api/appointments/{appointment_id}
```

Los resultados obtenidos permitieron identificar una debilidad en los controles de autorización a nivel de objeto, que posibilit a el acceso y la eliminación de turnos pertenecientes a otros usuarios.

El hallazgo se documentó individualmente y se clasificó mediante el sistema CVSS. La evaluación se limitó a las funcionalidad es y recursos definidos para esta práctica, sin representar una auditoría integral de todos los componentes de la aplicación.

3. Métricas y Distribución de Hallazgos

En esta sección se presenta un resumen estadístico de los hallazgos registrados durante la evaluación de seguridad. Las métricas se generan a partir de los tickets incorporados al informe y permiten visualizar la distribución de vulnerabilidades según su severidad, estado de resolución y categoría.

La información se organiza en los siguientes indicadores:

- **Distribución por severidad CVSS:** clasifica los hallazgos según su puntuación de riesgo, permitiendo identificar aquellos que requieren mayor prioridad de atención.
- **Distribución por estado:** muestra la situación actual de los tickets, diferenciando los hallazgos pendientes, en proceso de remediación y resueltos.
- **Distribución por categoría:** permite reconocer los tipos de vulnerabilidades identificadas y detectar patrones recurrentes.

Los resultados representan el estado de los tickets al momento de generar el informe y facilitan la identificación de prioridades y el seguimiento de las acciones correctivas.

Criterio de clasificación CVSS

La severidad de cada hallazgo se determina a partir de su puntuación base CVSS.

Se utilizan las siguientes categorías:

Severidad	Puntuación
Crítica	9.0 – 10.0
Alta	7.0 – 8.9
Media	4.0 – 6.9
Baja	0.1 – 3.9
Ninguna	0.0

Gráfico de torta con los tickets agrupados según severidad CVSS



Gráfico de barras con los tickets agrupados según su estado

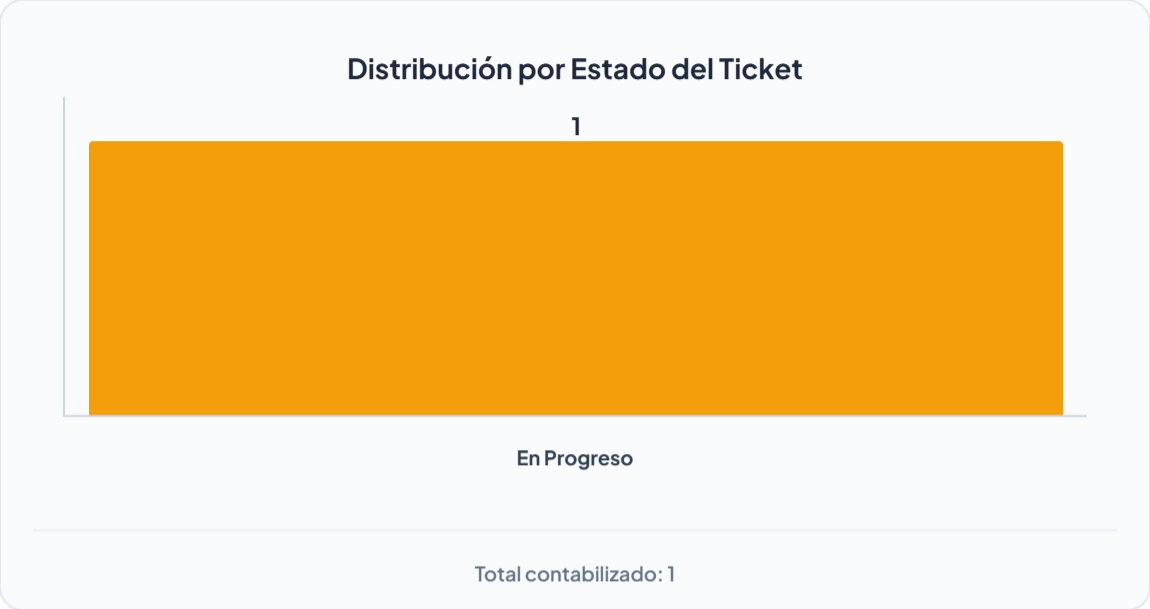


Gráfico de torta con los tickets agrupados según su categoría



4. Detalle de Vulnerabilidades e Incidencias Registradas

En esta sección se presenta el hallazgo identificado durante la evaluación de seguridad de la aplicación Turnero.

El hallazgo se encuentra documentado en el ticket **SSG-IDOR-001**, correspondiente a una vulnerabilidad de control de acceso de tipo IDOR/BOLA (Insecure Direct Object Reference / Broken Object Level Authorization).

El ticket incluye su clasificación de severidad mediante CVSS, los recursos afectados, la descripción técnica, el procedimiento de reproducción (PoC), las evidencias obtenidas durante las pruebas y las recomendaciones de remediación.

Esta información permite comprender el alcance del hallazgo, evaluar su impacto y facilitar su seguimiento y resolución por parte de los responsables técnicos.

HALLAZGO #1 En Progreso

Software Seguro v1.0.0

Plantilla: Hallazgo de Seguridad

Ref ID: SSG-IDOR-001

NOMBRE

Acceso y eliminación no autorizada de turnos de otros usuarios (IDOR/BOLA)

CATEGORÍA

Broken Access Control - IDOR / BOLA

VERSIÓN

N/A (No Aplica)

VECTOR CVSS

6.3 (CVSS:3.0/AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:L/A:L)

URL AFECTADA(S)

https://chl-227d92a0-000e-429d-bc29-47c148a14482-turnero.softwareseguro.com.ar/

ENDPOINTS AFECTADOS

```
GET /api/{user_id}/appointments/
DELETE /api/appointments/{appointment_id}
```

DESCRIPCIÓN

Se identificó una vulnerabilidad de control de acceso en el sistema Turnero que permite a un usuario autenticado consultar y cancelar turnos pertenecientes a otros usuarios, sin que el servidor valide correctamente la autorización sobre los recursos solicitados.

La aplicación utiliza identificadores numéricos en las rutas de su API para recuperar los turnos de un usuario y para cancelar turnos individuales. Al modificar estos identificadores en las solicitudes HTTP, fue posible acceder a información de otros usuarios y ejecutar operaciones de eliminación sobre sus turnos.

El comportamiento evidencia una validación insuficiente de permisos a nivel de objeto (IDOR/BOLA), ya que el servidor no comprueba adecuadamente que los turnos consultados o eliminados pertenezcan al usuario autenticado.

DETALLES DE LA VULNERABILIDAD

La vulnerabilidad se presenta en dos operaciones:

1. Consulta de turnos: el endpoint GET /api/{user_id}/appointments/ recibe el identificador del usuario directamente en la URL. Al reemplazar el identificador correspondiente

a la cuenta autenticada (luis, user_id=1) por el identificador 101, la API devolvió los turnos asociados al usuario xdalvik, sin exigir autorización adicional.

2. Cancelación de turnos: al analizar la solicitud utilizada por la aplicación para cancelar un turno propio, se identificó que el endpoint DELETE /api/appointments/{appointment_id} utiliza el identificador del turno como parámetro de la ruta. Al reemplazar el ID de un turno propio por los identificadores de los turnos pertenecientes a xdalvik, fue posible cancelar dichos turnos desde la sesión autenticada de luis.

La aplicación no realiza una validación efectiva de propiedad o permisos antes de permitir el acceso y la eliminación de los recursos.

CÓMO SE DETECTÓ

Se realizó una evaluación manual de los endpoints de la API relacionados con la consulta y cancelación de turnos. Durante el análisis se inspeccionaron las solicitudes HTTP generadas por la aplicación y se modificaron los identificadores utilizados para acceder a los recursos.

A partir de estas pruebas, se comprobó que el servidor no validaba correctamente la autorización sobre los recursos solicitados, permitiendo consultar y eliminar turnos pertenecientes a otros usuarios mediante la manipulación de identificadores en las rutas de la API.

PRUEBA DE CONCEPTO (POC)

Procedimiento de reproducción

1. Iniciar sesión en la aplicación utilizando una cuenta válida (`luis`).
2. Consultar los turnos asociados al usuario autenticado mediante la solicitud `GET /api/1/appointments/`.
3. Modificar el identificador de usuario en la ruta, reemplazándolo por `101`, y enviar `GET /api/101/appointments/`.
4. Comprobar que el servidor devuelve los turnos pertenecientes a `xdalvik`, incluyendo sus identificadores (10, 11, 12 y 13), sin requerir una autenticación diferente.
5. Identificar el endpoint utilizado para cancelar turnos: `DELETE /api/appointments/{appointment_id}`.
6. Desde la misma sesión autenticada como `luis`, enviar solicitudes DELETE reemplazando el identificador de un turno propio por los identificadores de los turnos de `xdalvik` (10, 11, 12 y 13).
7. Comprobar que el servidor responde con HTTP 200 y el mensaje `{"message":"Turno eliminado correctamente"}`.
8. Consultar nuevamente los turnos de ambos usuarios para verificar que los turnos de `xdalvik` fueron eliminados y que los de `luis` permanecieron intactos.

Resultado obtenido

Se confirmó que un usuario autenticado puede consultar y eliminar turnos pertenecientes a otros usuarios mediante la manipulación de identificadores en las solicitudes HTTP, sin que el servidor aplique controles de autorización a nivel de objeto.

RECOMENDACIONES

- Implementar controles de autorización en el servidor para todas las operaciones que i

- Implementar controles de autorización en el servidor para todas las operaciones que involucren recursos asociados a usuarios.
- Verificar que el usuario autenticado sea propietario del turno solicitado antes de permitir su consulta, modificación o eliminación.
- No confiar en los identificadores enviados por el cliente como mecanismo de autorización.
- Aplicar controles de acceso a nivel de objeto en todos los endpoints de la API.
- Responder con un código HTTP 403 Forbidden o 404 Not Found cuando un usuario intente acceder o modificar un recurso para el que no tiene autorización.
- Incorporar pruebas de seguridad que verifiquen que un usuario no pueda consultar ni cancelar turnos pertenecientes a otras cuentas.

5. Conclusiones y Plan de Remediación

A partir de las pruebas realizadas sobre la aplicación Turnero, se identificó una vulnerabilidad de control de acceso de tipo ID OR/BOLA, clasificada con severidad media y una puntuación CVSS de 6.3.

El hallazgo evidencia que los mecanismos de autorización de la aplicación no verifican adecuadamente la pertenencia de los turnos al usuario autenticado. Esta debilidad permite consultar información asociada a otros usuarios y eliminar sus turnos me diante la manipulación de identificadores en las solicitudes HTTP.

Si bien la vulnerabilidad no implica un compromiso general de la aplicación, representa un riesgo para la confidencialidad de l a información y la integridad y disponibilidad de los turnos administrados por el sistema.

Se recomienda priorizar su corrección mediante la implementación de controles de autorización a nivel de objeto en los endp oints afectados, verificando que cada usuario únicamente pueda consultar, modificar o eliminar los recursos sobre los cuales tiene permisos.

Prioridades de remediación

- **Prioridad crítica y alta:** no se identificaron hallazgos de estas categorías durante el alcance de la presente evaluación.
- **Prioridad media:** corregir la vulnerabilidad IDOR/BOLA identificada, incorporando validaciones de autorización del lado d el servidor en los endpoints de consulta y eliminación de turnos.
- **Prioridad baja e informativa:** evaluar mejoras adicionales en los mecanismos de control de acceso y fortalecer las prueba s de seguridad de la API.

Validación de las correcciones

Una vez implementadas las medidas correctivas, se deberán realizar nuevas pruebas para comprobar que un usuario autentic ado no pueda consultar ni eliminar turnos pertenecientes a otros usuarios.

La validación deberá contemplar tanto los endpoints de consulta como los de eliminación, verificando que las solicitudes no autorizadas sean rechazadas correctamente y que los usuarios legítimos puedan continuar operando sobre sus propios turn os.

El estado del hallazgo IDOR-
001 deberá actualizarse en su ticket correspondiente, manteniendo la trazabilidad de las acciones correctivas y los resultado s de las pruebas de validación.